

DNP3 ATTACK & DEFEND

The SCADA protocol under the North American grid — three sublayers, one control code, and no idea who you are.

IEEE 1815-2012 · DNP Users Group object library
Purdue L1–L2 · master ↔ outstation (RTU/IED) · long-haul WAN
16-bit link addresses, little-endian · CRC poly 0x3D65
Broken open by Project Robus — Crain & Sistrunk, 2013–14

DNP3 asks twice before it trips a breaker. Select arms the point, Operate fires it — and neither message asks who you are. **FC 5 Direct Operate** skips the first.

1 WHERE IT LIVES

STACK

DNP3/TCP 20000 — the master usually opens the socket
DNP3/UDP 20000 — rare, and broadcast-capable
DNP3 serial RS-232/485 — same three sublayers, no IP
Serial-over-TCP terminal server — **no standard port**
DNP3-SAV5 IEEE 1815-2012 auth — **no confidentiality**

PORTS

20000/tcp DNP3 — **Shodan port:20000**
20000/udp DNP3 over UDP, broadcast
19999/tcp dnp-sec / DNP3 over TLS — near-absent
no std port serial tunnel, cellular router, gateway

Master ↔ outstation. Control centre and SCADA front-end processor talking to RTUs, IEDs, protection relays, reclosers, pump stations.

THE LONG-HAUL LINK IS THE SOFT EDGE

Leased line, licensed radio, cellular, microwave. DNP3 legitimately crosses infrastructure you do not own, to sites nobody visits for months. Every one of those paths is an injection point that never touches your fence.

2 THE OBJECT LIBRARY

GROUP	VAR	OBJECT	ACC	WHAT IT IS
1 / 2	1-3	Binary Input / Event	R	breaker OPEN CLOSED, alarms
10 / 11	1,2	Binary Output Status / Ev	R	output point as it stands
12	1	Control Relay Output Blk	W	THE BREAKER — the CROB
20 / 22	1-8	Counter / Event	R	metering, accumulators
30 / 32	1-8	Analog Input / Event	R	MV, kV, pressure, level
40	1-4	Analog Output Status	R	the setpoint as it stands
41	1-4	Analog Output Block	W	SETPOINT WRITE
50	1,3,4	Time and Date	W	time sync — and time skew
60	1-4	Class 0 / 1 / 2 / 3 data	R	the polling shorthand
70	2-7	File transfer	RW	config + firmware movement
80	1	Internal Indications	RW	the IIN, as a written object
120	1-9	Secure Authentication v5	—	challenge / response

Every request is **<FC>** on **<GROUP>**. **<VARIATION>** over a **<QUALIFIER>**: **<RANGE>**.

⚠ THE POINT INDEX IS NOT AN ADDRESS

Group 12 index 7 is Feeder 4 only because the device profile says so. Indices are 0-based, per-group and vendor-assigned — two outstations from two vendors do not share a map, and the standard does not define one.
A capture alone tells you a breaker moved. It never tells you which breaker. Pull the point list with the PCAP or the evidence is half-blind.

3 FRAME ANATOMY

DNP3 LINK FRAME — three sublayers in every packet

05 64	LEN	CTRL	DEST	SRC	CRC
2 B	1 B	1 B	2 B LE	2 B LE	2 B

user data → 16-byte blocks, each + 2 B CRC poly 0x3D65
— TRANSPORT — 1 B — FIR | FIN | SEQ 6 bits
— APPLICATION — AC 1 B | FC 1 B | objects ... + IIN 2 B on 129/130

05 64 starts every frame. Off-port, a chance 0x0564 that fails CRC is **not DNP3**.
LEN counts CTRL → end of user data, excludes the CRCs. Max 255.
CTRL carries DIR, PRM, FCB/FCV and the data-link function code.
DEST / **SRC** are DNP3 link addresses — **not the IP. 0xFFFFD–0xFFFF broadcast**
CRC per 16-byte block — a mismatch on 20000 is **evidence, not noise**.

THE LINK ADDRESS IS A SECOND IDENTITY

Your firewall sees 10.30.4.12. The protocol sees outstation 47. Nothing in the frame binds them together.
Alert on the PAIR: a known master IP with an unexpected source link address, or a known link address arriving from a new IP.

4 FUNCTION CODES — THE WEAPON RACK

colour = what it does to the physical process

RECON	READ	WRITE	CONTROL / DESTRUCTIVE	AUTH
READ — 99% of a healthy DNP3 network is these four				
01 0x01	Read	Class & integrity polls · recon when the source is new		
129 0x81	Response	the outstation reply — carries the IIN		
130 0x82	Unsolicited Response	event push with no poll — enabled per point		
00 0x00	Confirm	link and application acknowledgement		
23 0x17	Delay Measurement	link timing 24 0x18 Record Current Time		

CONTROL — Select-Before-Operate, and the way round it

03 0x03	Select	arms a point — control intent, nothing moves	T0855
04 0x04	Operate	fires the armed point — a physical change	T0831
05 0x05	Direct Operate	NO Select. one message, identical result	T0831
06 0x06	Direct Operate No Ack	same again, and no response to correlate on	T0831

WRITE — state change without a control code

02 0x02	Write	outputs, TIME, configuration values	T0836
07 – 12	Freeze / Freeze & Clear	± time, ± no-ack — wipes accumulators	T0836
22 0x16	Assign Class	changes what gets reported, and when	T0856
20 0x14	Enable Unsolicited	flood or mask the event stream	
21 0x15	Disable Unsolicited	SILENCES the outstation — denial of view	T0815

DESTRUCTIVE — loss of control on one device, or on all of them

13 0x0D	Cold Restart	full outstation reboot	T0816
14 0x0E	Warm Restart	application restart	T0816
18 0x12	Stop Application	halts the outstation application	T0816
15 0x0F	Initialize Data	data points back to defaults	T0836
16 / 17	Init / Start Application	reinitialise, then run	T0855
19 0x13	Save Configuration	persist the running config to NVRAM	T0836
31 0x1F	Activate Configuration	commit a staged configuration	T0836

FILE — approximately never in normal telemetry

25 – 30 Open/Close/Delete/Info + Authenticate, Abort File — config & firmware T0845

AUTH — DNP3 Secure Authentication v5, where it is switched on

32 0x20	Authenticate Request	SAV5 is on the wire — not that it covers this FC
33 0x21	Authenticate Error	challenge failed, or the key is wrong

6 ATTACKER PLAYBOOK ICS Kill Chain — Stage 2

1 DISCOVER

Scan tcp/20000 — Shodan port:20000 still returns internet-facing outstations. Behind a serial gateway, sweep DNP3 destination link addresses 0–65519 to map every device on the loop from one IP.

2 FINGERPRINT

FC 1 Read of Group 60 Var 1 — a Class 0 integrity poll — returns the entire static point map: every binary input, analog, counter and output the outstation owns. No session, no credential. It is byte-identical to the master's own poll, so the recon is free.

3 MAP THE PROCESS

Walk Group 30/40 for values and Group 12/41 for controls. IIN Object-unknown and Parameter-error tell you exactly where the map ends. Group 80 hands you the outstation's own indications.

4 ARM

FC 3 Select against a control point — and stop. A confirmed Select proves the point is real and armable and moves nothing physical. Select-without-Operate is control-point enumeration, and it is invisible to anything watching only for Operate.

5 MANIPULATE

FC 4 Operate fires the armed point; FC 5/6 Direct Operate skips the Select entirely. CROB control code 0x81 trips, 0x41 closes. FC 2 Write moves analog setpoints and the clock. Aim any of it at link address 0xFFFFD–0xFFFF and it lands on every outstation at once.

6 BLIND & COVER

FC 21 Disable Unsolicited stops event reporting and the master keeps its last picture. FC 9/10 Freeze-and-Clear wipes the accumulators. FC 13/14 restart the device; FC 18 stops the application, FC 25–30 move files off it.

WHY IT WORKS

No authentication, no encryption, no message integrity in the base protocol. Select-Before-Operate is an interlock against a mis-click, not an authorisation step — and Direct Operate is in the same specification. SAV5 exists, is optional, and is frequently scoped to a subset of function codes on a subset of devices.

7 DEFENDER PLAYBOOK

capture → parse → triage

CAPTURE

bpf: tcp port 20000 trunk: (port 20000) or (vlan and port 20000)
Tap the control-LAN / RTU switch. A 20-outstation substation with integrity polls and Class 1 events runs ~10–50 MB/min. Include udp/20000 and the serial-gateway port.

ZEEL — ICSNPP-DNP3

dnp3.log · dnp3_control.log · dnp3_objects.log
fc_request, fc_reply, iin, dnp3_src, dnp3_dst — the control log decodes the CROB to trip/close with on/off time; the objects log gives group, variation, qualifier and range.

SURICATA / SNORT 3 — native dnp3 inspector

dnp3_func:operate; dnp3_func:direct_operate; dnp3_func:cold_restart; dnp3_ind:device_restart; dnp3_obj:12,1; dnp3_data; — CRC-stripped

WIRESHARK

dnp3.al.func in {3 4 5 6} dnp3.al.func in {13 14 18 21}
dnp3.al.iin.dr dnp3.src / dnp3.dst dnp3.al.obj == 0x0c01

TRIAGE — FIVE QUESTIONS, IN ORDER

- Is it a control, restart or config op? (2/3/4/5/6 · 13/14/18 · 15/16/19/31 · 21 · 25–30)
- From the authorised master? Check the source IP **and** the source link address, as a pair.
- Inside a change window, against a work order? 4 Did an Operate follow a Select to the same point?
- Broadcast address, or IIN Device Restart / Config Corrupt? → confirmed. **Non-master control or bypassed SBO — ESCALATE.**

★ THE HIGHEST-VALUE QUERY IN OT

Every DNP3 function code on the network that is not 1, 129 or 130.
Read, Response and Unsolicited Response are almost all of a healthy network — telemetry is polling, and polling is boring. Everything left over is the entire control plane, and on most utilities a month of it is short enough to read by eye and put a work order against every line.
If the list is too long to read, that is the finding — and detection is not the first job. Working out why your control plane is that noisy is.

8 NORMAL vs SUSPICIOUS

NORMAL

- one master, or a few redundant ones, to a fixed outstation set
- FC 1 Read + FC 129 Response at a steady poll cadence
- FC 130 Unsolicited only where it was explicitly enabled
- periodic FC 23 / 24 time sync from the master
- stable IP ↔ DNP3 link-address bindings, per device
- control (3 → 4) rare, in hours, operator-initiated, from the master
- IIN quiet — class-event bits and need-time, nothing else

SUSPICIOUS

- control FC from a non-master IP or link address — the finding**
- Operate with no preceding Select — SBO bypass, or a capture gap
- Select with no Operate — control-point enumeration
- Direct Operate 5 / 6 where the standard says Select-Before-Operate
- broadcast control to link address 0xFFFFD–0xFFFF
- Disable Unsolicited, Cold/Warm Restart or Stop Application off-hours
- file operations 25–30 against a telemetry outstation
- IIN Device Restart or Configuration Corrupt appearing unbidden
- bursts of Object Unknown / Parameter Error / FC-not-supported
- one source touching many DNP3 destination link addresses
- DNP3 on a public IP, or on a non-standard port
- CRC mismatch on port 20000

9 HARDENING

- Allowlist master → outstation pairs on both IP and DNP3 link address. The network IS the access control.
- Never expose 20000 to the internet. Check Shodan and Censys against your own ASN.
- Enable DNP3-SAV5 where the devices support it — and record which function codes it actually covers.
- Disable Direct Operate at the outstation wherever the engineering standard says Select-Before-Operate.
- Assign link addresses uniquely, and suppress response to broadcast where the device allows it.
- Alarm on FC 13 / 14 / 18 / 21 and on any file operation, unconditionally.
- Log the IIN, Device Restart and Configuration Corrupt should page a human.
- Terminate serial tunnels at a known gateway. Inventory every terminal server and cellular router.
- Keep the point list with the capture — evidence without the device profile is half-blind.

IEC 62443-3-3 · NIST SP 800-82r3 · NERC CIP-005 / 007 · IEEE 1815-2012 SAV5

10 ATT&CK for ICS

T0846 Remote System Discovery	scanning tcp/20000
T0888 Remote System Info Discovery	Class 0 integrity poll
T0840 Network Connection Enum	link-address sweep
T0885 Commonly Used Port	20000/tcp, 20000/udp
T0855 Unauthorized Command Message	Select / Operate from non-master
T0831 Manipulation of Control	CROB Operate on a breaker
T0836 Modify Parameter	Write, AO block, Save/Activate Config
T0806 Brute Force I/O	Select/Operate sweep across indices
T0816 Device Restart / Shutdown	FC 13 / 14, Stop Application 18
T0815 Denial of View	Disable Unsolicited 21
T0814 Denial of Service	poll starvation, restart bursts
T0856 Spoof Reporting Message	injected Unsolicited Responses
T0845 Program Upload	file operations 25–30
T0800 Activate Firmware Update Mode	file ops staging firmware

SEEN IN THE WILD

Project Robus — Crain & Sistrunk, 2013–14. Dozens of DNP3 stack flaws disclosed through ICS-CERT; a malformed frame from an **outstation** could crash the **master**. The trust runs both ways.